

CYBERSECURITY RISK MANAGEMENT PROJECT

Information Security Risk Management Project Report

Risk Management Plan, Asset Inventory, Risk Assessment, and Risk Mitigation for a
Faith Based Nonprofit Camp and Retreat Organization

Quinn Smith
University Of Wisconsin Platteville

Document Overview

This report brings together the six stages of a semester long risk management project completed for a faith based nonprofit organization that operates a retreat and event center and seasonal summer camps. The organization is referred to throughout as the organization or the camp. The work moves from initial contact with the organization, through planning, asset inventory, and risk assessment, to a plan for reducing the highest priority risks.

Part	Title	Contents
0	Organization Profile	Initial contact responses and organization details
1	Risk Management Plan	Introduction, goals and objectives, scope, compliance requirements, roles, system description, project schedule, and references
2	Asset Inventory	Fourteen IT assets with ownership, recovery objectives, vendor details, data handling, and business impact
3	Risk Assessment Scope and Systems	Assessment scope, asset identification, and descriptions and diagrams of three systems
4	Threat, Vulnerability, and Risk Analysis	Threats, vulnerabilities, existing controls, control gaps, qualitative method, and the risk assessment table
5	Risk Mitigation Plan	Recommended NIST SP 800-53 controls for five high priority risks

Part 0: Organization Profile

The following responses were gathered during initial contact with the organization at the start of the project.

#	Response
1	Daycoach Center
2	Retreat center / summer camp
3	40
4	Managing Director and Assistant Director (primary organizational contacts)
5	"Yes! There's not too much going on right now so we have plenty of time."

Table 0.1. Initial contact responses.

Part 1: Risk Management Plan

1.1 Introduction to the Organization

The organization is a faith-based nonprofit that operates as a retreat and event center and hosts seasonal summer camp programs for children, youth groups, and families. Its mission is to provide a safe, welcoming, and inclusive environment that supports youth development, faith formation, leadership training, and community engagement. It serves a diverse population that includes campers, parents, church groups, volunteers, and external organizations that rent the facilities for retreats and events.

The organization is small in terms of full-time administrative staffing, but its operational footprint expands significantly during peak seasons when seasonal employees and volunteers are onboarded to support programming. This seasonal workforce model creates unique operational and security challenges, particularly in the areas of account provisioning, data handling, and training.

From an information technology perspective, the organization maintains a limited internal IT presence. It employs two part-time staff members who handle basic on-site technical issues such as workstation troubleshooting and user support. The majority of IT operations, including infrastructure management, system maintenance, and technical security controls, are outsourced to a third-party managed service provider. According to available information, the managed service provider does not store organizational data on its own servers but instead provides management and support services for the organization's systems.

At the present time, the organization does not maintain a formal, structured risk management program. Interviews conducted with the primary organizational contact and an additional staff member confirmed that there is no documented risk management strategy, no formalized IT security governance framework, and no standardized process for identifying, assessing, or mitigating risk. Risk-related activities are handled in an informal and reactive manner, typically when a problem arises.

Key concern: The lack of formal structure increases the organization's exposure to operational, legal, financial, and reputational risks, particularly due to the sensitive nature of the data it collects and processes.

1.2 Goals and Objectives of the Risk Management Plan

Purpose of the Risk Management Plan

The purpose of this Risk Management Plan (RMP) is to establish a structured and repeatable process that enables the organization to identify, assess, mitigate, and monitor risks that could negatively affect its mission, operations, stakeholders, and information systems. The RMP will support proactive decision-making, improve regulatory compliance, enhance data protection, and ensure the continuity of critical services such as camp registration and financial processing.

Goals

- Protect sensitive data that relates to children and family personal information as well as medical information.
- Ensure availability of the online system to support camp registration and other daily operations.

- Keep the plan well documented so that a new person can take on a role when leadership changes.

Objectives

- Maintain 99.9% uptime on camp registration and other daily operations.
- Perform a risk assessment of all in-scope systems.
- Implement two-factor authentication (2FA) for sensitive information and remote access.

1.3 Scope and Boundaries

In Scope

The following systems and data environments are included in this Risk Management Plan:

- Camp registration database
- Retreat and event registration systems
- Payment processing systems
- Staff and HR records
- Organizational email platform
- Cloud services used for operations and communication

These systems are considered critical because they process sensitive personal, medical, and financial data and are essential for daily operations.

Out of Scope

The following areas are excluded from this phase of the plan:

- Detailed physical security controls
- Personal devices not owned or managed by the organization
- Non-organizational third-party systems not under contractual control

These areas may be addressed in future phases of the risk management program.

1.4 Compliance Requirements

Requirement	What It Is	Why It Matters to the Organization
HIPAA	The Health Insurance Portability and Accountability Act protects patient information from being disclosed to anyone other than the patient without consent.	The camp holds medical information for camp members, including medication records. This information needs to be protected from other campers, parents, and outside sources.
COPPA	The Children's Online Privacy Protection Rule imposes requirements on websites and their operators that knowingly collect personal information from children under the age of 13.	The camps are directed to children who will use the website. The organization needs to ensure that the website meets all requirements.
PCI DSS	The Payment Card Industry Data Security Standard is a security framework designed to protect credit card information.	Parents pay to send their children to camp. The organization must protect cardholder data and ensure that required measures, such as firewalls, are implemented.

Table 1.1. Compliance requirements.

1.5 Roles and Responsibilities

Role	Responsibilities
Executive Director	Approve the risk plan Ensure funding for risk management Oversee third-party vendor risk
Camp Director	Report security incidents Manage day to day camp activities
Office Manager	Oversee protection of camper and guest records Ensure compliance with policies and legal requirements
HR	Manage staff records Manage staff payment
Program Staff	Protect camper and guest information Report incidents or suspicious activity
IT Company	Handle risk on their end Conduct risk assessments

Table 1.2. Roles and responsibilities.

1.6 System Description and Diagram

Most of the network and IT systems are handled by a third-party IT service provider, which places them out of scope for this plan. The servers are also handled by the same third party. On site there are many end devices, such as PCs and laptops, that are owned by the camps. There are also personal devices brought by campers and employees. A large amount of data is stored at the main camp. Information on campers and payment information are stored at each camp as well.

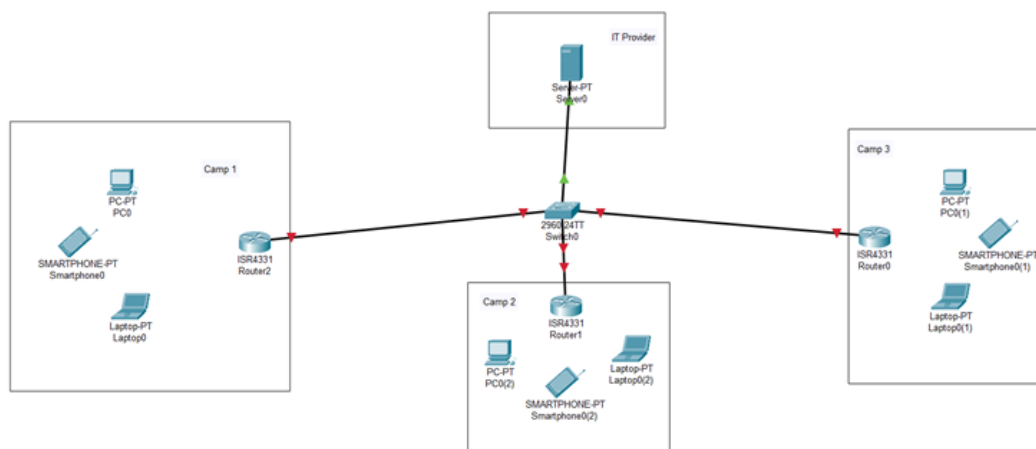


Figure 1.1. Network layout: three camp locations connect through a central switch to the IT provider.

1.7 Project Schedule

This is the project timeline for the duration of the class.

Task	Task Name	Duration (days)	Start Date	End Date	Predecessor	Person
1	RMP Research	12	02/18	03/01	N/A	Everyone
2	Asset Management	12	03/02	03/13	Task 1	Everyone
3	Risk Assessment Plan	16	03/22	04/05	Task 2	Everyone
4	Risk Mitigation Plan	14	04/06	04/19	Task 3	Everyone
5	Business Continuity Plan	14	04/20	05/03	Task 4	Everyone
6	Final Report + Presentation	14	05/04	05/17	Task 5	Everyone

Table 1.3. Project tasks, dates, and dependencies.

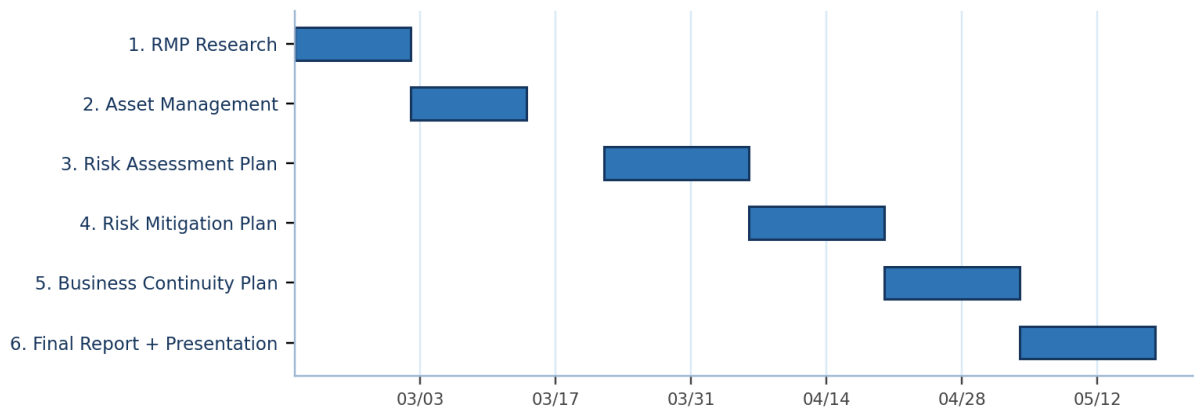


Figure 1.2. Project timeline.

References

Centers for Disease Control and Prevention. "Health Insurance Portability and Accountability Act of 1996 (HIPAA)." *Public Health Law*, Centers for Disease Control and Prevention, 10 Sept. 2024, www.cdc.gov/phlp/php/resources/health-insurance-portability-and-accountability-act-of-1996-hipaa.html.

Federal Trade Commission. "Children's Online Privacy Protection Rule ('COPPA')." *Federal Trade Commission*, Federal Trade Commission, 2025, www.ftc.gov/legal-library/browse/rules/childrens-online-privacy-protection-rule-coppa.

Microsoft. "Payment Card Industry (PCI) Data Security Standard (DSS) - Microsoft Compliance." *Learn.microsoft.com*, 26 Jan. 2023, learn.microsoft.com/en-us/compliance/regulatory/offering-PCI-DSS.

Part 2: Asset Inventory

The asset inventory records fourteen IT assets. It is presented in four tables that share the asset identifier: identification and recovery objectives, vendor and configuration, data handling and compliance, and backup, security, and business impact. Abbreviations used include RTO (Recovery Time Objective), RPO (Recovery Point Objective), and PAN (primary account number).

2.1 Identification and Recovery Objectives

ID	Asset Name	Category	Owner / Custodian	Importance / Criticality	RTO	RPO
IT001	Primary File & VM Host	Hardware	IT Department	5	4 hours	N/A
IT002	Domain Controller / SSO	Software / Network	IT Department	5	1 hour	15 minutes
IT003	Email & Collaboration (M365)	Software	IT Department / Admin	5	1 hour	4 hours
IT004	Registration & Payments Platform	Software	Operations / Finance	5	4 hours	1 hour
IT005	Finance / Accounting System	Software	Finance	5	8 hours	4 hours
IT006	HRIS & Personnel Records (incl. BG checks)	Data / Software	HR Manager	5	8 hours	4 hours
IT007	Camper Medical / Health Records	Data	Health Services / HR	5	4 hours	4 hours
IT008	Website & Public Portal	Software / Service	Marketing / IT	4	24 hours	12 hours
IT009	On-site Backup Appliance & Replication	Hardware	IT Department	4	8 hours	N/A
IT010	Network Infrastructure (firewalls)	Network	IT Department	5	1 hour	1 hour
IT011	On-site Workstations & Laptops (staff)	Hardware	Site Managers / IT	3	24 hours	N/A
IT012	Point-of-Sale Terminals (gift shop/canteen)	Hardware / Software	Site Manager	3	8 hours	1 day
IT013	IT Management & Monitoring Tools	Software	IT Department	4	4 hours	4 hours
IT014	Vendor / Third-Party SaaS Contracts (inventory record)	Data	IT Department	4	24 hours	24 hours

Table 2.1. Asset identification, ownership, criticality, and recovery objectives.

2.2 Vendor and Configuration

Asset	Manufacturer / Vendor	Model / Version	Location	Lifecycle Status	Configuration Details
IT001 Primary File & VM Host	Dell	PowerEdge R750	Data Center Room 101	In Support	VM hypervisor hosting core VMs (AD, file, backups); RAID, dual PSU
IT002 Domain Controller / SSO	Microsoft	Active Directory 2019	Primary DC, Data Center	In Support	Multi-DC topology, GPOs, Azure AD Connect
IT003 Email & Collaboration (M365)	Microsoft	Exchange Online / M365	Cloud	Current	Tenant-level configuration
IT004 Registration & Payments Platform	Vendor (SaaS)	Registration v2.1	Vendor-hosted (cloud)	Current	Customer DB, payment connector
IT005 Finance / Accounting System	QuickBooks Online or equivalent	Cloud SaaS	Cloud	Current	Multi-user accounting setup
IT006 HRIS & Personnel Records (incl. BG checks)	HRIS Vendor	BambooHR or similar	Cloud	Current	Encrypted personnel DB, role separation
IT007 Camper Medical / Health Records	Health forms vendor or encrypted repository	Forms system	Cloud and Health Office	Current	Encrypted medical records, limited access
IT008 Website & Public Portal	Managed Host / WordPress	Site + registration portal	Cloud	Current	Web server + CDN, staging
IT009 On-site Backup Appliance & Replication	Veeam + Synology or vendor	Backup appliance	Server Room	In Support	Deduplication, encryption, replication to cloud
IT010 Network Infrastructure (firewalls)	Fortinet, Cisco	FortiGate 100F, Cisco 9200 series	Data Center	In Support	Firewall: HA pair, core allow/deny policies, VPN, NAT, centralized logging
IT011 On-site Workstations & Laptops (staff)	Lenovo / Dell / Apple	Various	Office & field	In Support	Standard image, EDR agent installed
IT012 Point-of-Sale Terminals (gift shop/canteen)	Clover / ShopKeep or vendor	POS terminals	On-site	In Support	Local POS terminal, card reader
IT013 IT Management & Monitoring Tools	Vendor (e.g., Datto, SolarWinds)	Monitoring + backup management	Cloud / On-prem	Current	Patch management + monitoring
IT014 Vendor / Third-Party SaaS Contracts (inventory record)	Various	SaaS vendor list	N/A	Current	Contract metadata, contacts, SLAs

Table 2.2. Vendor, model, location, lifecycle status, and configuration.

2.3 Data Handling and Compliance

Asset	License / Compliance Info	Data Classification	Storage Location	Access Control / Permissions	Regulatory Requirement
IT001 Primary File & VM Host	Vendor support contract	Confidential	On-prem	Admin-only access	N/A
IT002 Domain Controller / SSO	Microsoft licensing	Confidential	On-prem / Azure AD hybrid	Admin-only access	FERPA where applicable
IT003 Email & Collaboration (M365)	Enterprise subscription	Confidential	Cloud	Role-based admin access	Data privacy regs (FERPA)
IT004 Registration & Payments Platform	Vendor PCI controls	Confidential	Cloud	Role-based access	PCI DSS required
IT005 Finance / Accounting System	Vendor license	Confidential	Cloud	Finance-only roles	Financial record keeping
IT006 HRIS & Personnel Records (incl. BG checks)	Vendor policy + confidentiality	Confidential	Cloud	HR-only access	State/background-check laws
IT007 Camper Medical / Health Records	Vendor confidentiality	Confidential	Cloud / Encrypted on-prem	Health staff only	HIPAA-like privacy and state rules
IT008 Website & Public Portal	Hosting subscription	Public / Confidential (portal)	Cloud	Admin author access	Privacy policy + data protection
IT009 On-site Backup Appliance & Replication	Vendor support	Confidential	On-prem + replicated to cloud	Admin-only	Data retention policy
IT010 Network Infrastructure (firewalls)	Vendor support	Confidential	On-prem	IT-admin	Security standards
IT011 On-site Workstations & Laptops (staff)	OS licensing	Confidential	On-prem / Local	User account + admin escalation	Data protection rules
IT012 Point-of-Sale Terminals (gift shop/canteen)	Vendor PCI controls	Confidential / Operational	Local + vendor cloud	Manager and finance access	PCI DSS scope (minimize)
IT013 IT Management & Monitoring Tools	Subscription agreements	Confidential	Cloud / On-prem	Admin-only access	N/A
IT014 Vendor / Third-Party SaaS Contracts (inventory record)	Contractual	Confidential	Cloud	IT & procurement access	Data protection clauses

Table 2.3. Licensing, data classification, storage, access control, and regulatory requirements.

2.4 Backup, Security Controls, and Business Impact

Asset	Backup / Recovery Info	Security Controls	Connectivity	Business Impact if Lost	Comments / Notes
IT001 Primary File & VM Host	Hourly VM snapshots + nightly replication to backup appliance	Host firewall, AV, OS hardening, ACLs	Internal LAN	Host failure impacts multiple services and halts operations	Hosts VM workloads
IT002 Domain Controller / SSO	AD-aware daily backups; VM replication	Kerberos/LDAPS, MFA for admins	Internal LAN & Cloud	Authentication outage prevents logins/services	Critical for user auth and policy enforcement
IT003 Email & Collaboration (M365)	Vendor retention & backup options	MFA, anti-phish, DLP, TLS	Cloud	Loss prevents official communications and workflows	Includes shared mailboxes and OneDrive storage
IT004 Registration & Payments Platform	Encrypted vendor backups + exported daily reports	WAF, TLS, vendor SOC2	Cloud	Loss stops new registrations and payments	Vendor handles PCI; reduce local storage of PANs
IT005 Finance / Accounting System	Vendor backups + export schedule	TLS, vendor security, MFA	Cloud	Loss impacts payroll/accounts payable and financial reporting	Data used for audits and payroll
IT006 HRIS & Personnel Records (incl. BG checks)	Daily encrypted backups	Encryption at rest, RBAC	Cloud	Loss risks compliance and workforce management	Holds background checks
IT007 Camper Medical / Health Records	Encrypted backups + secure retention	Encryption in transit/rest, strict ACLs	Cloud	Loss impairs medical care and legal compliance	Contains medication
IT008 Website & Public Portal	Daily backups and staging restore	WAF, TLS, plugin security	Cloud / Public	Loss impacts public info and registrations	Public site; portal connects to registration (no PANs stored)
IT009 On-site Backup Appliance & Replication	Hourly replication + daily cloud copy	Encryption at rest, secure replication	Internal LAN & Cloud	Loss prevents restores after failure	Used for VM and file-level recovery
IT010 Network Infrastructure (firewalls)	IT-admin access	Security standards	Internal	Loss of connectivity	Internal & guest wifi
IT011 On-site Workstations & Laptops (staff)	User backups to file server or cloud sync	Disk encryption, EDR, OS patches	Internal LAN / Remote	Loss reduces staff productivity and admin capability	Replaceable hardware but contains cached data
IT012 Point-of-Sale Terminals (gift shop/canteen)	Daily data sync to vendor + exports	TLS, tokenization, vendor PCI	Internal LAN & Cloud	Loss disrupts on-site sales and cash handling	Ensure tokenization and do not store PANs locally
IT013 IT Management & Monitoring Tools	Daily config backups	Alerts and logs; TLS, MFA, role separation	Not specified	Not specified	Not specified
IT014 Vendor / Third-Party SaaS Contracts (inventory record)	Contract copies in cloud + legal backup	Vendor SOC2 / encryption requirements	Cloud	Loss risks SLA and compliance visibility	Maintained list of vendor responsibilities and contacts

Table 2.4. Backup and recovery, security controls, connectivity, business impact, and notes.

Part 3: Risk Assessment Scope and Systems

3.1 Introduction

The purpose of this risk assessment is to identify, analyze, and evaluate risks to the information systems used by the organization. This assessment provides insight into threats, vulnerabilities, impacts, and likelihood to support decision-making.

This assessment is intended to produce:

- Identification of key risks
- Understanding of vulnerabilities
- Evaluation of potential impacts
- Prioritized risk information

It supports decisions related to security controls, resource allocation, compliance (HIPAA, COPPA, PCI DSS), and data protection.

3.2 Scope and Boundaries

Scope	Systems and Areas
In Scope	Camp registration system Payment processing system Email and cloud services
Out of Scope	Physical security Personal devices External unmanaged systems

Table 3.1. Assessment scope.

3.3 Asset Identification

Asset Type	Assets
Information Assets	Camper personal and medical data Payment data Employee records
System Assets	Registration systems Payment platforms Email / cloud systems
Hardware Assets	PCs and laptops
Service Assets	Third-party IT provider

Table 3.2. Identified assets.

3.4 System 1: Camp Registration System

Purpose	Supports camper registration and operations.
Components	Web app, database, authentication.
Data	Personal and medical data.
Users	Parents, staff.
Interfaces	Payment system, email.
Dependencies	Internet, cloud provider.

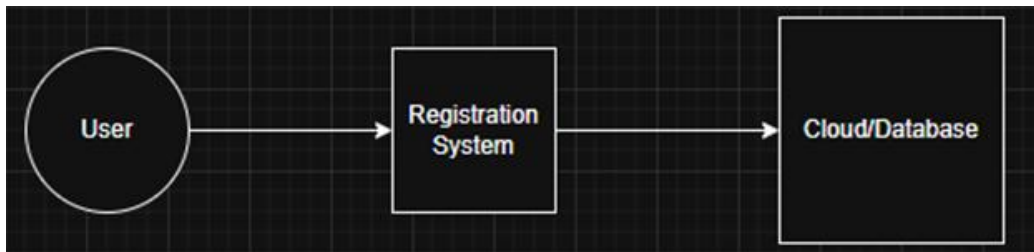


Figure 3.1. Camp registration system data flow.

3.5 System 2: Payment Processing System

Purpose	Handles financial transactions.
Components	Payment gateway.
Data	Credit card data.
Users	Parents, finance staff.
Interfaces	Banks.
Dependencies	Third-party provider.

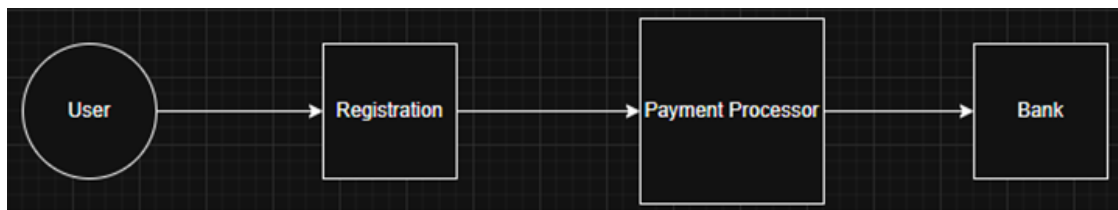


Figure 3.2. Payment processing system data flow.

3.6 System 3: Email and Cloud Services

Purpose	Communication and storage.
Components	Email, cloud storage.
Data	Emails and attachments.
Users	Staff.
Interfaces	External contacts.
Dependencies	Cloud provider.

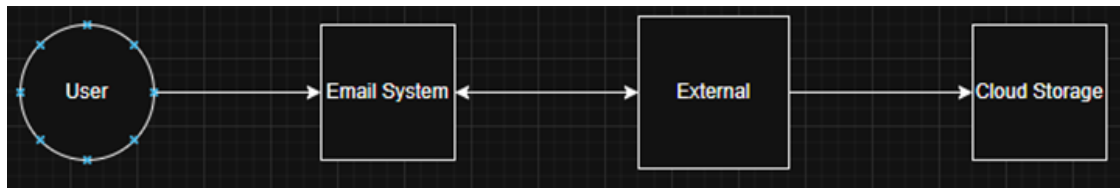


Figure 3.3. Email and cloud services data flow.

Part 4: Threat, Vulnerability, and Risk Analysis

4.1 Threat Identification

Adversarial Threats

Threat Actor	Attack Types	Impact
Cybercriminals	Ransomware, credential stuffing, dark-web data sales	Financially motivated. Target registration/payment systems for PII and card data resale. High attack volume globally.
Hackers	SQL injection, privilege escalation, zero-day exploits	May act for personal gain, notoriety, or targeted disruption. Exploit technical weaknesses in web-facing systems.
Phishing Attackers	Spear phishing, BEC, malicious links/attachments	Exploit human trust via email/cloud channels. Often serve as the initial vector for larger breaches or account takeovers.

Table 4.1. Adversarial threats.

Non-Adversarial Threats

Threat Type	Examples	Impact
Human Error	Misconfigured settings, accidental data exposure, wrong recipients	Leading cause of data breaches. Errors during routine admin or maintenance can expose sensitive records unintentionally.
System Failures	Server crashes, software bugs, hardware faults, API timeouts	Unplanned downtime can corrupt transaction records or expose partially completed payment data, affecting data integrity.
Natural Events	Flooding, power outages, wildfires, earthquakes	Physical infrastructure disruption can render systems unavailable. Cloud reliance mitigates but does not eliminate this risk.

Table 4.2. Non-adversarial threats.

Threat Events

Registration System

Threat Event	Method	Impact
SQL Injection	Malicious SQL queries via form inputs	Full database read/write; exfiltration of all user PII and credentials
Unauthorized Access	Brute force, stolen credentials, session hijacking	Account takeover, identity theft, unauthorized data modification
Data Breach	Insecure APIs, unpatched software, misconfiguration	Mass exposure of user records; regulatory/legal liability (GDPR, CCPA)

Payment System

Threat Event	Method	Impact
Credit Card Theft	Card skimming, form hijacking (Magecart-style)	Financial fraud for users; PCI-DSS violations and heavy fines for the organization
Man-in-the-Middle	Interception of unencrypted traffic, SSL stripping	Real-time capture of payment credentials and session tokens
Third-Party Compromise	Supply-chain attack on payment processor or SDK	Loss of control; cascading breach affecting all customers using that processor

Email / Cloud

Threat Event	Method	Impact
Phishing	Deceptive emails impersonating trusted entities	Credential theft, malware installation, account compromise
Malware	Email attachments, malicious links, drive-by downloads	Data encryption (ransomware), exfiltration, persistent backdoor access
Unauthorized Access	Weak passwords, no MFA, misconfigured cloud permissions	Exposure of stored emails, documents, and cloud-hosted data assets

Table 4.3. Threat events by system.

4.2 Vulnerabilities and Severity

Vulnerability	Severity	Explanation	Justification
Weak Input Validation	High	User-supplied input is not properly sanitized or validated before processing.	Directly enables SQL injection and cross-site scripting (XSS). A single unvalidated field can expose the entire database.
Poor Authentication	High	Authentication mechanisms lack sufficient rigor, for example no account lockout or weak session management.	Allows brute-force and credential-stuffing attacks to succeed at scale, enabling full account takeover.
Third-Party Reliance	Medium	Dependence on external payment processors, cloud providers, or APIs for core functionality.	Security posture is partially outside direct control. A breach at a vendor directly translates to exposure for users.
Lack of Encryption	High	Sensitive data (PII, payment info) is stored or transmitted without adequate encryption (for example no TLS, plaintext storage).	Enables successful MitM attacks and renders stolen data immediately usable by attackers. Violates PCI-DSS and GDPR requirements.
Weak Passwords / No MFA	High	User and admin accounts rely solely on passwords, which may be weak, reused, or compromised via phishing.	Password-only authentication is routinely defeated. MFA is the single most effective control for preventing unauthorized access.
Lack of User Awareness	Medium	Staff and users are not trained to recognize phishing, social engineering, or safe data-handling practices.	Human error is the leading cause of breaches. Untrained users are the primary target for phishing and BEC attacks regardless of technical controls.

Table 4.4. Vulnerabilities and severity ratings.

4.3 Existing Controls

Registration System

Control	Description	Addresses
Authentication Controls	Login mechanisms including username/password verification and session management to restrict system access.	Unauthorized access, account takeover
Cloud Security	Cloud provider security features such as network isolation, identity and access management (IAM), and infrastructure monitoring.	Data breaches, system failures

Control	Description	Addresses
Access Restrictions	Role-based access control (RBAC) limiting which users and administrators can view or modify specific data and system functions.	Insider threats, privilege escalation

Payment System

Control	Description	Addresses
PCI DSS Compliance	Adherence to a set of security standards formed by major card brands to protect cardholder data.	Data breaches, legal non-compliance, heavy fines, and loss of merchant status.
Secure Payment Gateway	An e-commerce service that authorizes and processes credit card payments using secure, encrypted channels.	Interception of payment data during transmission, fraudulent transactions, and unauthorized access to payment networks.
Payment System Encryption	Encoding payment data (like credit card numbers) into ciphertext both at rest and in transit so it can only be read with a decryption key.	Data theft, exposure of sensitive financial information, and man-in-the-middle (MITM) attacks.

Email / Cloud System

Control	Description	Addresses
Authentication	Verifying the identity of a user or system trying to access the network (for example Multi-Factor Authentication (MFA), passwords, biometrics).	Unauthorized access, credential stuffing, account takeovers, and identity theft.
Cloud Security Tools	Software and platforms (like CASBs, SIEMs, or firewalls) designed to monitor, detect, and protect cloud infrastructure from threats.	Malware, data leaks, misconfigurations, advanced persistent threats (APTs), and lack of visibility in cloud environments.
Access Permissions	Defining and restricting user privileges (for example Role-Based Access Control) to ensure users only access data necessary for their job.	Insider threats, accidental data deletion, privilege escalation, and unauthorized data exposure.

Table 4.5. Existing controls by system.

Control Gaps

1. No MFA controls are documented for any system, leaving all authenticated access dependent on password strength alone.
2. No input validation or output encoding controls are referenced, leaving the Registration System exposed to injection attacks.
3. No encryption controls (TLS enforcement, at-rest encryption) are documented for the Payment System or cloud storage.
4. No security awareness training program is referenced, leaving the Email/Cloud environment highly susceptible to phishing-based compromise.
5. No controls are documented for the Payment System or Email/Cloud environments beyond the Registration System's three baseline controls.

4.4 Qualitative Risk Assessment Approach (Based on NIST SP 800-30)

Likelihood Scale

Level	Definition
Very High	Threat is very highly likely to occur (frequent attacks or easy to exploit)
High	Threat is highly likely to occur (frequent attacks or easy to exploit)
Moderate	Threat may occur (some controls exist, but still possible)
Low	Threat is unlikely to occur (strong controls or rare scenario)
Very Low	Threat is very unlikely to occur (strong controls or rare scenario)

Impact Scale

Level	Definition
Very High	Very severe impact (data breach, financial loss, reputational damage)
High	Severe impact (data breach, financial loss, reputational damage)
Moderate	Noticeable impact (service disruption, limited data exposure)
Low	Minimal impact (minor inconvenience, little to no damage)
Very Low	Minimal to no impact (minor inconvenience, little to no damage)

Risk Level Determination

Risk is determined by combining likelihood and impact:

Risk Level	Combination
Very High Risk	Very High Likelihood + Very High / High Impact
High Risk	High Likelihood + High / Moderate Impact
Moderate Risk	Moderate Likelihood + Moderate Impact
Low Risk	Low Likelihood + Low / Moderate Impact
Very Low Risk	Very Low Likelihood + Very Low / Low Impact

Basic Risk Assessment Steps

1. Identify assets (data, systems, hardware)
2. Identify threats (hackers, phishing, human error)
3. Identify vulnerabilities (weak passwords, no MFA, poor training)
4. Determine likelihood (High, Moderate, Low)
5. Determine impact (High, Moderate, Low)
6. Assign overall risk level (High, Moderate, Low)
7. Prioritize risks for mitigation

Examples from the Assessment

Threat	Likelihood	Impact	Risk
SQL Injection	High	High	High
Phishing	Moderate	High	Moderate
Malware	Moderate	Moderate	Moderate

Control Gaps (Summary)

- No MFA
- Limited training
- Third-party dependency risks
- Lack of monitoring

4.5 Risk Assessment Table

Each threat event is evaluated for its source, the characteristics of that source (capability, intent, and targeting), its relevance, the likelihood that an attack is initiated and succeeds, the vulnerabilities that make it possible, its severity, and the resulting impact and level of risk.

Threat Event	Threat Source	Threat Source Characteristics			Relevance	Likelihood of Attack Initiation	Vulnerabilities and Predisposing Conditions	Severity and Pervasiveness	Likelihood Initiated Attack Succeeds	Overall Likelihood	Level of Impact	Level of Risk
		Capability	Intent	Targeting								
SQL Injection	External Attacker	Moderate: Tools available that are easy to deploy	Low: Is not concerned with detection	Low: Targets an internet-facing web app with known vulnerabilities	Possible	High	Unpatched web app, no input validation, internet-facing portal, no WAF	High	High	High	High	High
Unauthorized Access	External Attacker, Malicious Insider	Moderate: Credential lists are available and tools can automate login attempts	Moderate: Wants to establish connection on specific data	Moderate: Publicly available information to identify camp registration systems	Possible	High	No MFA, weak passwords, no lockout policy	High	High	High	High	High
Phishing	External Attacker / Ransomware Operator	Moderate: Phishing kits and social engineering skills are required	Moderate: Seeks to establish connection for ransomware deployment	Low: Uses publicly available information to target	Possible	Moderate	No security awareness; staff regularly interface with outside contacts	Moderate	Moderate	Moderate	High	Moderate
Malware	Ransomware Operator	High: Ransomware providers supply tools to affiliates	High: Wants to impede camp operations and extort money	Low: Targets small nonprofits with sensitive data and limited defenses	Possible	Moderate	No backup plan, no endpoint detection	High	Moderate	Moderate	High	Moderate
Third-Party Compromise	External Attacker Targeting IT Provider	High: Supply-chain attacks require significant reconnaissance and skill	High: Looks to maintain persistent presence across multiple organizations	Moderate: Analyzes publicly available information to identify organizations dependent on a single IT provider	Possible	Moderate	No audit logging of IT provider, IT has access to all systems, payment gateway security posture	High	Moderate	Moderate	High	High

Table 4.6. Risk assessment of five threat events. Shading: red = High, amber = Moderate.

Part 5: Risk Mitigation Plan

This part presents the risk mitigation plan for the five high-priority risks identified in the risk assessment. Each risk lists the assets it affects, the rating it received during the risk assessment, and the recommended NIST SP 800-53 controls with a justification for each.

#	Risk	Rating	Recommended Controls
1	Improper Access to Sensitive Data Due to Custom Application Weaknesses	20	SI-10, SA-11
2	Data Privacy and Personal Information Exposure	16	CM-7, SC-7
3	Phishing and Social Engineering Attacks	15	AT-2, SI-8
4	Unsecured Network Infrastructure	16	SC-32, AC-17
5	Ransomware and Malware Infection	14	SI-3, IR-4

Table 5.1. Summary of high-priority risks and recommended controls.

5.1 Improper Access to Sensitive Data Due to Custom Application Weaknesses

This high-priority risk affects camper medical records, HRIS data, and personal records databases. The risk received a rating of 20 during the risk assessment.

Recommended NIST 800-53 Controls

Control	What It Does	Justification
SI-10: Information Input Validation	Validates all user input before processing to help prevent attacks such as SQL injection, malicious scripts, and corrupted data submissions.	Reduces the exploitability of vulnerabilities within custom applications and helps protect sensitive data from unauthorized access.
SA-11: Developer Security Testing and Evaluation	Requires security testing such as vulnerability scans, penetration testing, and code reviews before applications are deployed.	Reduces threat impact by identifying weaknesses before systems are placed into production.

5.2 Data Privacy and Personal Information Exposure

This high-priority risk affects payment card data and financial systems of the camp. The risk received a rating of 16 during the risk assessment.

Recommended NIST 800-53 Controls

Control	What It Does	Justification
CM-7: Least Functionality	Configures the system to only provide the necessary functionality and restricts ports, protocols, software, and services.	Reduces access to the data and helps protect it from unauthorized access.
SC-7: Boundary Protection	Monitors externally managed interfaces to the system and implements subnetworks for publicly accessible system components.	Protects the card information entered by users in the payment portal.

5.3 Phishing and Social Engineering Attacks

This high-priority risk affects staff email accounts, financial systems, and administrative credentials. The risk received a rating of 15 during the risk assessment.

Recommended NIST 800-53 Controls

Control	What It Does	Justification
AT-2: Literacy Training and Awareness	Implements security and privacy literacy training, including lessons about internal or external security incidents and literacy training techniques.	Helps staff learn about infiltration techniques and reduces the possibility of staff falling for attacks.
SI-8: Spam Protection	Employs spam protection mechanisms at system entry and exit points and updates spam protection when new releases are available.	Most phishing and social engineering attacks come through staff email. Spam protection should reduce the number of attack emails that come through the system.

5.4 Unsecured Network Infrastructure

This high-priority risk affects camp-wide Wi-Fi networks, administrative systems, and staff devices. The risk received a rating of 16 during the risk assessment.

Recommended NIST 800-53 Controls

Control	What It Does	Justification
SC-32: System Partitioning	Partitions the system into separate domains.	Should help secure the network by separating system components.
AC-17: Remote Access	Establishes usage restrictions, connection requirements, and implementation guidance. Authorizes each type of remote access to the system prior to the connection.	Remote access is used by many staff and campers. Establishing restrictions will help secure the network.

5.5 Ransomware and Malware Infection

This high-priority risk affects camp administrative systems, medical records, and financial data. The risk received a rating of 14 during the risk assessment.

Recommended NIST 800-53 Controls

Control	What It Does	Justification
SI-3: Malicious Code Protections	Implements malicious code protection mechanisms to detect and eradicate malicious code. These mechanisms can scan the system and files that are downloaded, opened, or executed.	Reduces the likelihood of malware or ransomware infecting the system, helping to protect the system and the information in it.
IR-4: Incident Handling	Implements incident handling capability for incidents like ransomware and malware. Plans include preparation, detection, analysis, containment, eradication, and recovery of the system.	Assists camp staff in isolating problems and recovering the system if an event occurs, reducing the impact of the event.

